RFC v0.3 — Modelagem de Risco Antifraude Pix

Status: Draft v0.3 · 17/10/2026 · Proposta para discussão, não política bancária calibrada. Alteração pontual desde a v0.2: identidade do destinatário, documentada na seção 14.

Origem: desafio QI Tech Antifraude Pix. Cenários, sinais, pesos e políticas abaixo são proposta de modelagem da equipe, não exigências regulatórias nem resultados validados com dados reais. Números do Banco Central aparecem como referência citada, não como obrigação do desafio.

1. Problema, objetivo e escopo

O endpoint `POST /pix/transaction` recebe o ID do Pix, o valor em centavos, a data/hora com fuso, os dados das contas pagadora e destinatária (incluindo data de abertura e CPF/CNPJ do titular) e a origem do pedido (`device_id`, `channel`, `ip` e `geolocation` opcional). Responde `approved`, `two_factor_required` ou `rejected`; `GET /pix/transaction/{id}` devolve a análise gravada. Todo pedido recebido e sua decisão ficam gravados, inclusive rejeições e pedidos de 2FA.

Objetivo: avaliar, no momento da autorização, indícios de uso não autorizado da conta pagadora e de destino suspeito, com explicação auditável e o mínimo de fricção para clientes legítimos. Risco de fraude não é o mesmo que valor alto, falta de histórico ou erro cadastral. O 2FA ajuda sobretudo contra tomada de conta; não resolve golpes em que o próprio pagador foi convencido a transferir.

Fora do escopo inicial: aprendizado de máquina e modelos de linguagem; consulta ao DICT (Diretório de Identificadores de Contas Transacionais); saldo, livro contábil ou liquidação; biblioteca de telemetria do aparelho; cadastro e onboarding de contas; validações regulatórias que dependam de dados que não recebemos. Regras obrigatórias ficam na validação de entrada (JSON Schema) e nas constraints do banco. `approved` não significa liquidação realizada.

2. Conceitos: do dado observado à decisão

Separamos o que recebemos, o que calculamos, como interpretamos e como decidimos, para que cada decisão possa ser explicada depois. Exemplo: o sistema observa sete tentativas do mesmo pagador em cinco minutos (característica); a regra verifica se foram pelo menos cinco (condição); o resultado é o sinal de frequência elevada (evidência); esse sinal soma pontos ao risco do pagador; a política decide se pede autenticação adicional.

Glossário

- **Característica (feature):** dado bruto ou derivado. Ex.: `tx_count_5m=7`, `payer_device_seen_before=false`, `recipient_age_days=2`.
- **Regra de detecção:** condição determinística e versionada sobre features, com pré-condições de disponibilidade. Ex.: `tx_count_5m >= 5`.
- **Sinal:** resultado interpretável da regra: `triggered`, `not_triggered` ou `unavailable`, com família, eixo, evidência e pontos. Falta de informação não vale como sinal negativo.
- **Pontuação de risco:** índice heurístico de indícios observados, não probabilidade calibrada de fraude. Dois eixos: `payer_risk` (comportamento e acesso do pagador) e `recipient_risk` (destino, rede e relação entre as partes).
- **Suficiência das evidências:** quanto histórico existe para sustentar as comparações de cada eixo. Usamos `unavailable` / `low` / `medium` / `high`, com contagens e janela, em vez de um número falsamente preciso.
- **Política de decisão:** tabela ordenada de condições que transforma pontuações, sinais e suficiência em status e motivos. Sem árvore treinada.
- **Primeira observação (cold start):** primeira vez que o pagador ou o destino aparece na nossa base. Não é o mesmo que conta recém-aberta.

Exemplo: feature `tx_count_5m=7` → regra `>= 5` → sinal P04 (pagador, +20) → agregação por família → política. Uma validação de contrato, por outro lado, devolve erro de API sem pontuar risco.

3. Contrato da API e erros

Entrada de `POST /pix/transaction` (contrato do desafio; valores em **centavos**):

```
{
  "id": "pix-000123",
  "amount": 150000,
  "transaction_date": "2026-10-17T22:15:00-03:00",
  "source_account": { "branch": "0001", "account_number": "88213",
    "opening_date": "2025-03-02T10:00:00-03:00",
    "owner": { "document_number": "123.456.789-09" } },
  "destination_account": { "participant": "60701190", "branch": "3675", "account_number":
"10442",
    "opening_date": "2026-10-10T09:00:00-03:00",
    "owner": { "document_number": "987.654.321-00" } },
  "source": { "device_id": "dvc-9f2c71a8", "channel": "app", "ip": "198.51.100.23",
    "geolocation": { "latitude": -23.56, "longitude": -46.65 } }
}
```

Saída (os três campos do contrato; `metadata` é livre e é onde mora a explicação):

```
{
  "key": "8f0c2b1e-5d7a-4c1e-9b3a-2f6d7e8a9c10",
  "status": "two_factor_required",
  "metadata": {
    "policy_version": "v0.2",
    "decision_rule": "D-ATO-1",
    "reasons": ["Dispositivo nunca visto para este pagador com valor 6,2x acima da median
a"],
    "scores": { "payer": 46, "recipient": 8 },
    "evidence_sufficiency": { "payer": "high", "recipient": "low" },
    "signals": [
      { "code": "P03", "family": "Perfil", "axis": "payer", "status": "triggered", "point
s": 18,
        "evidence": { "payer_prior_tx": 24, "device_seen_before": false } },
      { "code": "P06", "family": "Perfil", "axis": "payer", "status": "triggered", "point
s": 18,
        "evidence": { "amount": 620000, "median_amount": 100000, "ratio": 6.2 } },
      { "code": "P09", "family": "Perfil", "axis": "payer", "status": "not_triggered", "po
ints": 0 }
    ]
  }
}
```

Regras de contrato:

- **Normalização:** `document_number` vira só dígitos (11 = CPF, 14 = CNPJ) antes de qualquer agregação; a máscara não entra na chave de histórico.
- **Idempotência:** `UNIQUE(external_id)` no banco. Primeiro POST → 201 com a análise. Reenvio idêntico → 200 com a **mesma** análise, sem contar de novo no histórico. Mesmo `id` com payload diferente → 409. Corrida entre dois POSTs iguais: o segundo cai em `IntegrityError`, que o controller captura e trata como reenvio (nunca 500).
- **Fuso:** toda regra de horário usa `transaction_date` convertido para `America/Sao_Paulo`. O banco roda em UTC: no SQL usar `AT TIME ZONE 'America/Sao_Paulo'`; no Python, `.astimezone()`. No exemplo acima, `EXTRACT(HOUR)` dá 1 em UTC e 22 em SP.
- **Segurança e LGPD:** toda rota, exceto `/` e `/health_check`, exige `INTERNAL-TOKEN` (variável de ambiente). Logs de entrada/saída com `request_id`; CPF/CNPJ nunca aparece inteiro no log.

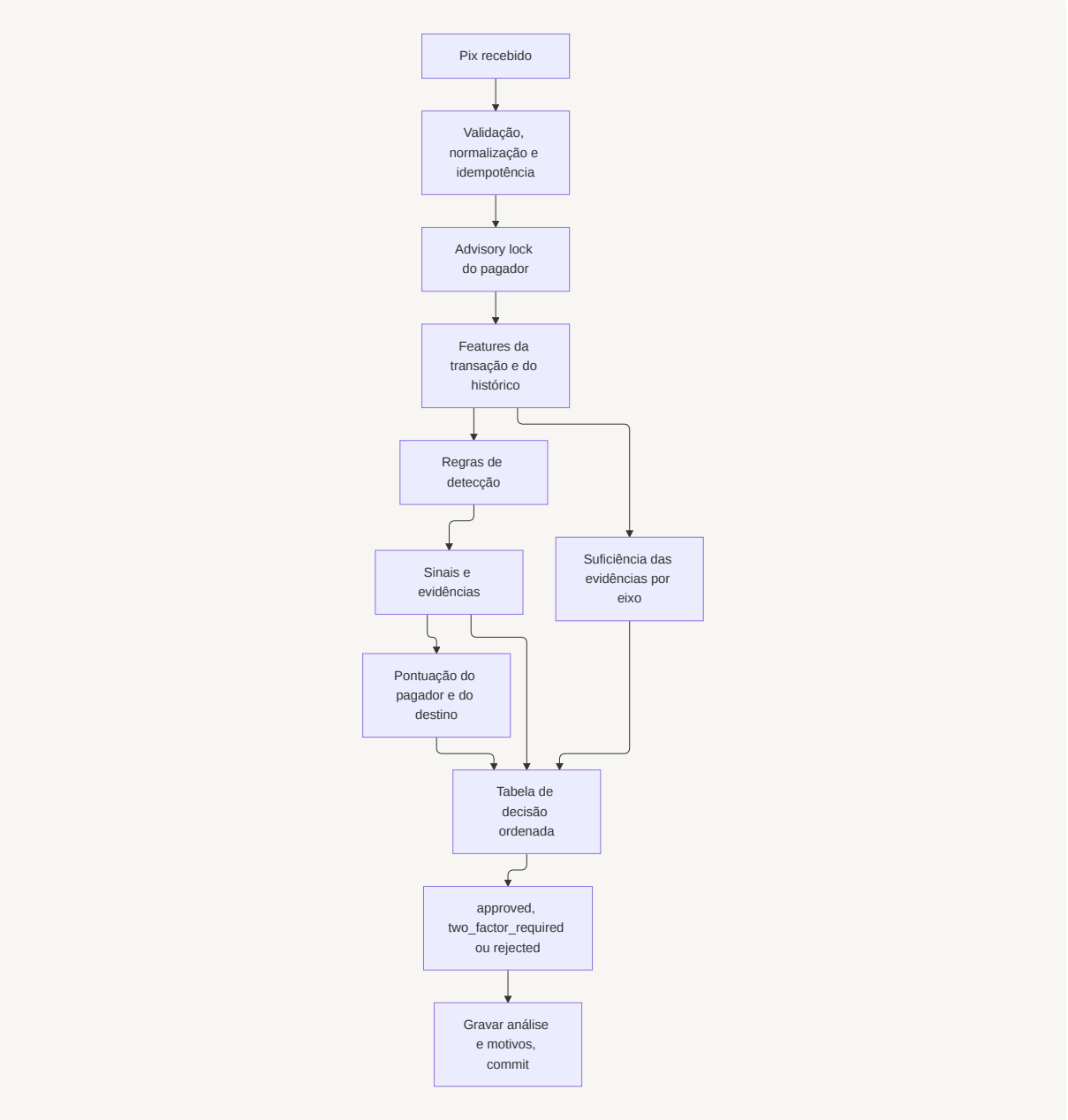
Erros previstos (uma classe em `errors/` por recusa, no formato `{title, description, translation, code}` do Base Service; códigos `QIT` seguem a numeração já existente no repositório):

HTTP	Classe	Quando
400	erro de schema do Base Service	payload fora do JSON Schema (`additionalProperties: false` , tipos, tamanhos, ISPB `^\d{8}$` , documento com 11 ou 14 dígitos)
403	erro de token do Base Service	`INTERNAL-TOKEN` ausente ou inválido
404	`PixTransactionNotFound`	`GET` de um `id` que nunca chegou
409	`PixTransactionIdConflict`	mesmo `id` com payload diferente do gravado
500	(sem nome, de propósito)	exceção não prevista; ver seção 8

4. Como o motor funciona, passo a passo

A implementação é determinística: os mesmos dados, o mesmo histórico e a mesma versão da política produzem a mesma análise. A validação de contrato acontece antes da análise de risco.

1. Validar o contrato, normalizar documentos e garantir idempotência por `id` .
2. Abrir a transação e pegar o advisory lock do pagador (seção 8). Ler o histórico anterior ao Pix atual e derivar features por pagador, destino, par pagador→destino, dispositivo e IP, em janelas móveis. Registrar o que ficou `unavailable` .
3. Aplicar as regras de detecção e guardar a evidência de cada uma. Regra sem pré-condição satisfeita retorna `unavailable` , não zero.
4. Somar por família, com teto por família para não contar o mesmo padrão várias vezes; somar por eixo, limitado a 0–100.
5. Calcular a suficiência das evidências do pagador e do destino separadamente.
6. Aplicar a tabela de decisão na ordem da seção 7.
7. Gravar payload, sinais, pontuações, suficiência, versão da política, regra de decisão, status e motivos, e dar `commit` como última linha do controller. Responder no contrato, com a explicação em `metadata` .



5. Catálogo de sinais

Para cada linha, a pergunta é: que comportamento tentamos detectar e por que ele importa? A coluna "Golpe" aponta o número da matriz golpe × sinal (`pesquisa-fraudes-pix-matriz.md`); a coluna "Família" usa as famílias sugeridas no desafio (Limite (?), Velocity, Montante, Perfil (Payer), Contraparte (Recipient)). Um sinal isolado nunca é tratado como prova de fraude.

Como ler:

- Pontos positivos aumentam a suspeita; negativos reduzem moderadamente quando há contexto favorável.
- "Requer histórico" significa que a regra devolve `unavailable` quando faltam observações.
- Valores em reais, janelas e pontos são hipóteses da equipe para simulação, salvo quando a coluna "Por quê" cita o Banco Central.
- **Contagem:** velocity e montante (P04, P05, P07, R02, R03, L02) contam **todas as tentativas** recebidas (`approved`, `two_factor_required` e `rejected`), porque a rajada em si é o sinal. Reenvios idempotentes não contam. A mediana de perfil (P06) usa só `approved`.

- **Duas identidades do destino:** (1) **titular destinatário**, identificado pelo CPF/CNPJ normalizado, para agregar movimentos destinados à mesma pessoa ou empresa mesmo quando utiliza contas diferentes; (2) **conta destinatária**, identificada pela combinação `participant` (ISPB) + `branch` + `account_number`, para características próprias da conta, como data de abertura e relacionamento com uma conta específica. Manter ambas as chaves disponíveis e registrar em cada sinal a granularidade usada. Isso evita perder uma rede distribuída em várias contas sem atribuir a uma conta individual o histórico ou a idade de outra conta do mesmo titular. Os campos permanecem disponíveis no payload armazenado; pode-se derivar a chave composta no serviço ou persistir uma coluna própria se necessário.

Código	Sinal	Condição	Pontos	Família	Golpe (matriz)	Histórico e interpretação
P01	Conta pagadora recém-aberta	`payer_age_days < 7`	Pagador +10	Perfil	#13 (laranja como origem)	Só a data de abertura informada; conta nova não prova fraude
L01	Valor alto no período noturno	hora em SP entre 20h e 6h **e** `amount > 100000` (R$ 1.000)	Pagador +8	Limite	#14, #11	Referência: limite noturno de R$ 1.000 do BC (coerção, roubo). Aqui é sinal fraco, não teto duro
L02	Dispositivo inédito acima do limite de device novo	P03 disparado **e** (`amount > 20000` **ou** soma do dia nesse device `> 100000`)	Pagador +10	Limite	#12, #11, #7	Referência: R$ 200 por Pix e R$ 1.000 por dia para dispositivo não cadastrado (BC). Não sabemos se o device é cadastrado no banco; usamos "nunca visto aqui"
P03	Dispositivo nunca visto para o pagador	`device_id` atual sem registro com o documento pagador	Pagador +18	Perfil	#9, #11, #7	Requer ≥3 observações anteriores do pagador; no cold start é `unavailable`
P04	Muitas tentativas em 5 min	≥5 tentativas do pagador nos 5 min anteriores, contando a atual	Pagador +20	Velocity	#9, #10, #18	Requer histórico; reenvios idempotentes não contam
P05	Montante alto na última hora	soma em 1 h, contando a atual, `> 800000` (R$ 8.000)	Pagador +15	Montante	#18, #1	Requer histórico; teto conjunto com P04
P06	Valor muito acima do padrão	`amount > 5 ×` mediana do pagador **e** `amount ≥ 100000`	Pagador +18	Perfil	#1, #6, #7	Requer ≥10 operações `approved` em ≥7 dias; mediana evita outlier; sem divisão por zero
P07	Vários destinos inéditos em pouco tempo	≥3 destinos nunca pagos antes em 10 min	Pagador +18	Velocity	#9, #10	Requer histórico; padrão de esvaziar a conta
P08	Dispositivo em vários pagadores	mesmo `device_id` com ≥3 documentos pagadores em 24 h	Pagador +12	Perfil	#21	Aparelho compartilhado pode ser legítimo; sinal de apoio
P09	IP nunca visto para o pagador	`ip` atual sem registro com o documento pagador	Pagador +6	Perfil	#9, #11	Requer histórico; IP móvel e VPN

Código	Sinal	Condição	Pontos	Família	Golpe (matriz)	Histórico e interpretação
						mudam; isolado não pede 2FA
P10	Dispositivo e IP inéditos juntos	P03 **e** P09 disparados	Pagador +12	Perfil	#9, #11	Interação; dentro do teto da família comportamental
R01	Conta destino recém-aberta	`recipient_age_days < 7` para a **conta específica** indicada no Pix, não para todas as contas do mesmo titular	Destino +12	Contraparte	#13, #4	Sozinho não bloqueia
R02	Muitas entradas no mesmo destino	≥5 tentativas para o mesmo **titular destinatário (documento normalizado)** em 10 min, mesmo que use contas diferentes	Destino +16	Velocity	#8, #13	Só enxerga o tráfego desta API
R03	Muitos pagadores para o mesmo destino	≥4 documentos pagadores distintos para o mesmo **titular destinatário (documento normalizado)** em 1 h, mesmo que use contas diferentes	Destino +20	Contraparte	#8, #13	Negócio legítimo também recebe de muitos pagadores
R04	Conta nova concentrando pagadores	R01 **e** R03	Destino +15	Contraparte	#13	Interação, não evidência independente; dentro do teto de rede
REL01	Destino inédito para o pagador	nenhum Pix anterior no par **pagador→titular destinatário**; a familiaridade com uma conta exata pode ser uma feature adicional, sem substituir esta regra	Destino +8	Contraparte	#1, #4, #6	Requer pagador já observado; cold start não conta como relação suspeita
REL02	Relação recorrente	≥3 Pix anteriores no par em ≥7 dias, sem anomalia recente	Destino −8	Contraparte	—	Histórico não prova destino seguro; nunca anula sinal grave
REL03	Mesmo titular	documento pagador = documento destino	Destino −5	Contraparte	—	Autotransferência não é proibida nem basta para aprovar

A antiga P02 (00h–05h e R$ 3.000) foi substituída pela L01; o motivo está na seção 13.

Histórico de acesso: guardar, por pagador, os dispositivos e IPs vistos, com primeira e última observação e número de tentativas, sem inflar a contagem com reenvios. "Dispositivo inédito na base" não é "recém-cadastrado no banco": não temos data de cadastro.

Fora desta versão: reputação de IP (não há lista), impossible travel (geolocalização é opcional e pouco confiável; ausência não é sinal), data de cadastro do dispositivo, saldo zerado, DICT, fraude confirmada (não há rótulos). IP, canal e geolocalização ficam gravados para exploração futura.

6. Pontuação de risco e suficiência das evidências

A pontuação responde "quantos indícios preocupantes temos e quão fortes são?". A suficiência responde "temos histórico bastante para fazer as comparações comportamentais?". Uma transação pode ter poucos sinais e pouco histórico sem que isso signifique segurança.

Tetos por família (evitam contar o mesmo padrão várias vezes):

Grupo	Sinais	Teto
Limite	L01, L02	15
Conta pagadora	P01	10
Velocity e montante do pagador	P04, P05	25
Comportamento do pagador	P03, P06, P07, P08, P09, P10	45
Rede do destino	R01, R02, R03, R04	35
Relação	REL01 (+8); REL02 e REL03 limitados a −10	+8 / −10

Cada eixo é a soma das famílias, limitada a 0–100. 70 pontos não são 70% de chance de fraude.

Suficiência por eixo, a partir de operações anteriores, dias observados, dispositivos vistos e relações anteriores: nenhuma observação = `unavailable`; 1 a 5 = `low`; 6 a 29 em mais de um dia = `medium`; ≥30 distribuídas em ≥7 dias = `high`. Podemos conhecer bem o pagador e quase nada do destino.

Sem histórico, avaliamos só os sinais intrínsecos (P01, L01, R01, REL03) e devolvemos `unavailable`: nem pontuação baixa por falta de registro, nem pontos por desconhecimento. A suficiência não vira penalidade numérica; ela liga e desliga regras históricas e aparece no `metadata`.

7. Como as pontuações viram decisão

A política é uma tabela de condições avaliadas **em ordem**; vale a primeira que casar. O tipo de intervenção precisa combinar com a origem do risco: 2FA ajuda quando outra pessoa pode estar usando a conta, mas não impede a vítima de um golpe de autorizar o envio. Por isso a rejeição fica reservada a destino com indícios combinados, e o 2FA a suspeita sobre o pagador.

Ordem	Linha	Condição	Status	Por quê
0	—	payload inválido ou mesmo `id` com conteúdo diferente	erro 400 / 409	Integridade e idempotência, não fraude
1	D-REJ	R01 **e** R03 **e** R02 disparados no destino	`rejected`	Conta nova recebendo de muitos pagadores em rajada: padrão de laranja e isca (#8, #13). 2FA do pagador não protege contra destino ruim. A pré-condição são as próprias contagens (≥4 pagadores, ≥5 entradas); não exigimos suficiência "em mais de um dia", que uma conta de 2 dias nunca teria
2	D-ATO-1	P03 **e** P06 disparados	`two_factor_required`	Dispositivo nunca visto com valor muito fora do padrão: suspeita de tomada de conta (#7, #9, #11)
3	D-ATO-2	P03 **e** P09 disparados	`two_factor_required`	Dispositivo e IP novos ao mesmo tempo: troca de ambiente de acesso (#9, #11)
4	D-PAY	`payer_risk ≥ 40`	`two_factor_required`	Soma de indícios sobre o pagador; o step-up pode mitigar uso não autorizado
5	D-RCP	`recipient_risk` entre 40 e 69	`two_factor_required` (com ressalva)	Único meio-termo do contrato; num produto real, um alerta explicando o golpe seria melhor
6	D-OK	nenhuma das anteriores	`approved`	Sem evidência que justifique fricção; evita punir cold start e falso positivo

`decision_rule` no `metadata` registra qual linha decidiu. Não rejeitar só por conta nova, horário ou valor. Esta API só pede o 2FA; não executa a verificação.

8. O que guardar, concorrência e falhas

A base enxerga só o que passou por esta API, não o Pix do país inteiro. Sinais de rede (R02, R03) são locais.

Modelo de dados (alinhado ao `database.sql` decidido):

- `pix_transaction_status`: os três status.
- `pix_transaction`: payload e decisão, 1:1. `external_id` com `UNIQUE`; documentos pagador e titular destinatário normalizados como coluna; ISPB, agência e número da conta no JSONB `pix_transaction_data`, compondo a **identidade da conta destinatária** separadamente da identidade do titular; `transaction_date` e `opening_date` em `TIMESTAMPTZ`. Consultas por conta exata usam esses três componentes; se necessário para desempenho, criar uma chave derivada/índice próprio, sem substituir o documento do titular.
- `pix_transaction_rule_result`: uma linha por regra avaliada em cada Pix (inclusive `unavailable`), com pontos e evidência. É daqui que sai `metadata.signals`.
- Índices `(eixo, transaction_date)` para pagador, device, IP e documento destino: toda velocity vira Index Only Scan.
- Pontuações por eixo, suficiência, `policy_version` e `decision_rule` ficam gravados junto da análise (JSONB da análise), para o `GET` devolver exatamente o que foi decidido mesmo depois de mudar pesos. *(Pendente: confirmar a coluna no schema.)*

Histórico e tempo: janelas com fronteiras explícitas; consultar só o que existia antes do Pix atual e somar o atual uma única vez. Nunca reavaliar um caso usando dado que chegou depois.

Concorrência: `pg_advisory_xact_lock(hashtext(documento_pagador))` no controller, antes da primeira consulta de regra, na mesma transação do INSERT (READ COMMITTED). Custo zero entre pagadores diferentes; serializa o mesmo pagador. Isso fecha a corrida das regras por pagador (P04, P05, P07, L02). Regras por destino, device e IP aceitam a corrida: são limiares, não saldo.

Falha do motor: exceção não prevista vira 500 e o rollback desfaz tudo, inclusive o registro do Pix. O cliente reenvia com o mesmo `id` e a idempotência garante uma única análise. Lacuna conhecida: um Pix que só gerou 500 não fica no histórico.

9. Cenários de aceitação (18)

Dois tipos: (a) comportamento antifraude e (b) integridade da API e do histórico (cenário 15). Cada cenário prepara o histórico **pela porta da frente** (POSTs anteriores, não INSERT), envia o Pix e confere status, `decision_rule`, sinais disparados, `unavailable` e pontuações. Os resultados são do motor v0.2, não rótulos de fraude real. Todos os testes são black box via HTTP e não importam nada de `src/`.

#	Cenário	Preparo e Pix enviado	Esperado (v0.2)	Teste
01	Primeira observação normal	1º Pix na base; contas com >1 ano; R$ 150 de dia	`approved`; suficiência `unavailable` sem penalidade	`test_primeira_observacao_normal_aprova`
02	Primeira observação, valor alto à noite	1º Pix; R$ 5.000 às 03h; contas maduras	`approved`; L01 +8, sinais históricos `unavailable`	`test_primeiro_pix_noturno_alto_aprova_com_l01`
03	Conta destino nova isolada	R$ 350; destino aberto há 2 dias; pagador regular	`approved`; R01 sozinho não barra	`test_destino_novo_isolado_aprova`
04	Mesmo titular	mesmo CPF dos dois lados; valor usual; histórico suficiente	`approved`; REL03 −5	`test_autotransferencia_aprova`
05	Relação recorrente	≥3 Pix ao mesmo destino em ≥7 dias; valor típico	`approved`; REL02 −8	`test_destino_recorrente_reduz_risco`
06	Device novo com valor fora do padrão	≥10 operações em ≥7 dias; device atual inédito; valor	`two_factor_required` por D-ATO-1	`test_device_novo_e_valor_atipico_pede_2fa`

#	Cenário	Preparo e Pix enviado	Esperado (v0.2)	Teste
		>5× mediana e ≥R$ 1.000		
07	Device novo isolado	device inédito; R$ 100 a destino recorrente	`approved`; P03 sozinho não basta, L02 não dispara	`test_device_novo_valor_baixo_aprova`
08	Frequência elevada	4 tentativas em <5 min e a atual é a 5ª; valores pequenos	`approved`; P04 +20 abaixo de 40	`test_quinta_tentativa_em_5min_dispara_p04_e_aprova`
09	Fracionamento para vários destinos	≥5 tentativas em 5 min, >R$ 8.000 na hora, ≥3 destinos novos em 10 min	`two_factor_required` por D-PAY (P04+P05 com teto 25 + P07 18 = 43)	`test_fracionamento_multidestino_pede_2fa`
10	Volume alto legítimo	pagador frequente, device recorrente, valores compatíveis, sem destinos novos	`approved`	`test_volume_alto_habitual_aprova`
11	Destino popular estabelecido	destino maduro com ≥4 pagadores em 1 h	`approved`; R03 +20 abaixo de 40	`test_destino_maduro_com_muitos_pagadores_aprova`
12	Concentração em destino novo	destino de 2 dias; ≥4 pagadores distintos em 1 h; ≥5 entradas em 10 min	`rejected` por D-REJ	`test_destino_novo_concentrando_pagadores_rejeita`
13	Pagador típico, destino suspeito	pagador normal; destino como no 12	`rejected` por D-REJ; 2FA do pagador não resolve	`test_pagador_normal_para_destino_suspeito_rejeita`
14	Informação incompleta	sem `geolocation`; resto habitual	`approved`; ausência não soma risco	`test_sem_geolocalizacao_aprova`
15	Reenvio e concorrência	mesmo Pix 2×; depois mesmo `id` com payload diferente; POSTs simultâneos do mesmo pagador na borda da P04	201 e depois 200 com a mesma análise; 409 no divergente; contagem única; lock serializa o pagador	`test_reenvio_devolve_mesma_analise`, `test_mesmo_id_payload_diferente_409`, `test_concorrencia_mesmo_pagador_conta_uma_vez`
16	IP novo, device habitual	pagador conhecido; valor normal; destino recorrente	`approved`; P09 aparece, sem 2FA	`test_ip_novo_isolado_aprova`
17	Device e IP novos juntos	histórico suficiente; device e IP	`two_factor_required` por D-ATO-2	`test_device_e_ip_novos_pedem_2fa`

#	Cenário	Preparo e Pix enviado	Esperado (v0.2)	Teste
		inéditos; valor moderado		
18	Device novo com valor atípico	≥10 operações em 7 dias; device inédito; valor >5× mediana	`two_factor_required` por D-ATO-1	`test_device_novo_valor_5x_mediana_pede_2fa`

Testes de fronteira (um par por limiar): P01 com 6 e 7 dias; L01 às 19:59 e 20:00, 05:59 e 06:00, `amount` 100000 e 100001; L02 com 20000 e 20001; P04 com 4 e 5 tentativas; P05 com 800000 e 800001; P06 com 5,0× e 5,01×; R03 com 3 e 4 pagadores; R02 com 4 e 5 entradas. Também: 403 sem token, 404 em `GET` inexistente, 400 com campo extra.

10. Limites conhecidos

O que este motor não pega, e por quê (útil na apresentação):

- **Fora do payload:** comprovante falso (#3), Pix agendado cancelado (#5), aumento de limite (#15), abuso do MED (#19) e Pix Automático/parcelado/biometria (#20). Nada disso aparece no que recebemos.
- **Só por proxy:** "Pix errado" com devolução para outra chave (#2) e Pix por aproximação (#16) dependeriam de dados que não temos (entrada anterior e tipo de pagamento).
- **Sinais invisíveis:** nome do recebedor, chave Pix, ligação ativa, app de acesso remoto e QR trocado. Pegamos só o efeito: destino novo, device novo, valor atípico.
- **Engenharia social:** em falsa central e falso parente (#1, #6), quem autoriza é a própria vítima. O 2FA cria uma pausa, não uma proteção. Um produto real precisaria de alerta contextual.
- **Visão local:** R02 e R03 só enxergam o tráfego desta API.

11. Questões abertas e ordem de implementação

1. Calibrar pesos e limiares com dados simulados, medindo aprovação, 2FA, rejeição e latência. Sem rótulos reais, não afirmar precisão, recall ou probabilidade de fraude.
2. Confirmar no schema onde ficam pontuações, suficiência e `policy_version` (seção 8).
3. Decidir se um destino com risco entre 40 e 69 deve continuar em 2FA ou ser aprovado com metadados (limitação do contrato).
4. Ordem: features e regras intrínsecas → histórico e janelas → agregação por eixo e suficiência → tabela de decisão → testes de sequência e fronteira.
5. Futuro: rótulos e feedback pós-transação para calibrar custo de intervenção; experimento offline com ML tabular, sem LLM na autorização em tempo real.

12. Da RFC ao README

O README do desafio é obrigatório e a correção começa por ele. Cada seção sai daqui:

Seção do README	Fonte nesta RFC
Como o motor de decisão funciona	seções 4 e 8
Regras (Regra / Lógica / Parâmetros / Por quê)	seção 5: Condição = Lógica; Pontos e janelas = Parâmetros; Golpe e Histórico = Por quê
Como as regras viram decisão	seções 6 e 7
Como rodar e testar	seção 9 + `docker compose up` e `pytest`

13. Descartado e o preço

Alternativa	Por que saiu	Voltaria se
Rejeitar por `recipient_risk ≥ 70`	Inalcançável com os tetos (máximo do destino ≈ 43); casos 12 e 13 nunca rejeitavam	Pesos forem recalibrados com dados

Alternativa	Por que saiu	Voltaria se
P02 com 00h–05h e R$ 3.000	Sem justificativa externa; a referência do BC é 20h–6h e R$ 1.000	O time preferir menos fricção noturna
Usar exclusivamente a tripla ISPB + agência + conta como identidade do destino	Perderia a concentração de Pix no mesmo titular através de contas diferentes. A v0.3 conserva também a chave da conta para sinais específicos.	Não substituir o documento: usar as duas granularidades conforme o sinal.
Velocity só com `approved`	Atacante insistente ficaria invisível depois de ser barrado	—
Fail-safe em 2FA quando o motor falha	Gravaria decisão que nenhuma regra produziu	O 500 virar problema operacional
Árvore de decisão treinada / ML	Sem rótulos; menos explicável	Houver feedback pós-transação
Impossible travel por geolocalização	Campo opcional e pouco confiável	Geolocalização passar a ser obrigatória

14. Critérios de aceite da v0.2

- Feature, regra, sinal, pontuação e suficiência estão separados, com `unavailable` explícito.
- Os dois eixos, a regra de decisão e a versão da política são gravados e voltam no `GET`.
- Primeira observação não vira segurança nem culpa.
- Tetos por família evitam dupla contagem; a política é uma tabela ordenada e versionada.
- Os 18 cenários e os testes de fronteira rodam via HTTP contra a API de pé.
- Todo limite, janela e peso é identificado como hipótese da equipe ou referência do BC citada.

Changelog v0.2 → v0.3 — identidade do destinatário

- Separação explícita entre **titular destinatário** (CPF/CNPJ normalizado) e **conta destinatária** (ISPB + agência + número da conta).
- R02 e R03 continuam agregando por titular para detectar concentração distribuída entre contas; R01 passa a explicitar que a idade é da conta específica. REL01 permanece relação pagador→titular; familiaridade com conta específica pode ser medida separadamente.
- **Por quê:** usar apenas o documento mistura atributos de contas distintas; usar apenas a conta fragmenta o histórico de um mesmo beneficiário. As duas chaves preservam a granularidade e a explicação de cada sinal, sem acrescentar pontuação ou alterar a política de decisão.
- Impacto técnico: conservar documento normalizado e os três campos bancários no armazenamento e informar a chave utilizada nas consultas/resultado da regra. Os testes devem incluir o mesmo titular com duas contas de idades diferentes e recebimentos divididos entre elas.

Changelog v0.1 → v0.2

- Política: a rejeição passa a ser a regra combinada D-REJ (a de score ≥70 era inalcançável); condições especiais viram linhas D-ATO-1 e D-ATO-2; casos 02, 08 e 11 fixados em `approved`.
- Nova família Limite (L01 substitui P02; L02 para dispositivo novo), ancorada em referências do BC.
- Colunas Família e Golpe no catálogo.
- Nova seção 3 (contrato, `metadata`, erros, idempotência, fuso, LGPD).
- Seção 8 alinhada ao schema: destino por documento, advisory lock por pagador, contagem de todas as tentativas, 500 + rollback em falha.
- Novas seções: limites conhecidos, RFC → README, descartado e o preço; cenários com nome de teste e testes de fronteira.
- Revisão de texto: termos em português, nomes de campos do contrato (`device_id`), erros de tradução.